

AVANCE DE PROYECTO INTEGRADOR

Controles de seguridad

Nombre del
alumno:

Luis Alberto Vargas Gonzalez

I. Administración de servicios de seguridad

Servicio de Gestión de Identidades y Acceso (IAM / Active Directory):

- Es vital para administrar centralizadamente a los **35,000 empleados** y eliminar el riesgo del "full access" generalizado, permitiendo aplicar el principio de menor privilegio.

Servicio de Almacenamiento y Respaldo de Datos (Backup as a Service):

- Dado que actualmente solo se respalda una cuarta parte de la información, se requiere un servicio que garantice la integridad y disponibilidad de los diseños premium y datos de manufactura.

Servicio de Conectividad Segura y Perimetral (VPN y Firewalls Next-Gen):

- Necesario para interconectar de forma segura las plantas ensambladoras con el centro de diseño en Múnich y permitir el acceso remoto seguro a los ingenieros de software.

Servicio de Protección de Endpoints (EDR - Endpoint Detection and Response):

- Para sustituir las versiones gratuitas de antivirus y proteger las **15,000 computadoras** (Windows y macOS) contra amenazas avanzadas ransomware.

Servicio de Gestión y Seguridad de Bases de Datos (Database Security):

- Crucial para monitorear y proteger los motores **DB2, Oracle y SQL Server** que llevan 3 años sin parches, asegurando la continuidad del proceso de manufactura.

II. Administración de riesgos

1. Infección por Malware/Ransomware: Debido al uso de antivirus gratuitos (Avast Free) en los 10,000 equipos personales, lo que deja a la empresa sin protección proactiva ante ataques modernos.

2. Acceso No Autorizado y Fuga de Información: Provocado por la política de "Full Access" generalizado, permitiendo que cualquier empleado acceda o modifique diseños premium de software y hardware sin restricción.

3. Explotación de Vulnerabilidades Críticas en Bases de Datos: Los motores Oracle, DB2 y SQL Server llevan 3 años sin parches de seguridad, lo que facilita ataques de inyección o robo de datos de manufactura.

4. Interrupción de Operaciones por Falla de Red: El equipo Cisco con más de 5 años de antigüedad y sin actualizaciones de firmware aumenta la probabilidad de caídas del sistema y huecos de seguridad en el perímetro.

5. Pérdida Irrecuperable de Datos Críticos: La falta de capacidad de almacenamiento para respaldos (solo se cubre el 25%) implica que ante un desastre, la mayoría de la información de diseño se perdería para siempre.

6. Intrusión Física a Áreas Restringidas: La inoperatividad de las cámaras de seguridad y la falta de control en los gafetes de proximidad permiten que personas no autorizadas ingresen a laboratorios de desarrollo.

7. Daños Físicos al Personal en Múnich: La zona sísmica de alta peligrosidad combinada con la inexistencia de un plan de evacuación pone en riesgo la vida de los ingenieros en el centro de diseño.

8. Introducción de Amenazas vía Shadow IT: La libertad de los empleados para instalar software (como *Warzone* o *AnyDesk*) introduce puertas traseras y malware en la red corporativa bajo el radar de TI.

9. Robo de Propiedad Intelectual: La falta de convenios de confidencialidad y control de invitados facilita que los diseños de autos deportivos y premium sean filtrados a la competencia.

10. Indisponibilidad del Servicio por Mantenimiento Prolongado: Ventanas de mantenimiento de hasta 2 días sin esquemas de alta disponibilidad afectan la productividad de las plantas ensambladoras a nivel mundial.

III. Soluciones de seguridad

Implementación de Control de Acceso Basado en Roles (RBAC) con MFA:

- Se debe desplegar un sistema de Gestión de Identidades (IAM) que elimine el "Full Access" generalizado, asignando permisos mínimos necesarios a los **35,000 empleados** y requiriendo Autenticación de Múltiple Factor (MFA) para acceder a los diseños premium de software y hardware.
- **Atiende:** Servicios de seguridad e Intercambio de información.

Infraestructura de Respaldo Híbrida con Redundancia Geográfica:

- Expandir la capacidad de almacenamiento para cubrir el 100% de la información crítica mediante una solución híbrida (Local + Nube), asegurando que los datos del centro de diseño en Múnich tengan réplicas en una zona de bajo riesgo sísmico para garantizar la disponibilidad.
- **Atiende:** Respaldos.

Renovación de Perímetro y Segmentación de Red (NGFW):

- Sustituir el equipo Cisco obsoleto por Firewalls de Nueva Generación (NGFW) que permitan segmentar la red de las plantas industriales de la red de oficinas, utilizando túneles VPN cifrados para el intercambio de datos entre sucursales y el centro de diseño.
- **Atiende:** Seguridad de red e intercambio de información.

Despliegue de Protección Avanzada de Endpoints (EDR):

- Instalar una solución de detección y respuesta en los **15,000 equipos** (Windows y macOS) para sustituir el antivirus gratuito. Esta herramienta permitirá bloquear la ejecución de software no autorizado (como *Warzone*) y detectar comportamientos sospechosos de ransomware en tiempo real.
- **Atiende:** Servicios de seguridad y Riesgos enlistados.

Blindaje y Monitoreo de Bases de Datos (Database Vault):

- Implementar soluciones de cifrado y "parchado virtual" para los motores **Oracle, DB2 y SQL Server**. Esto protege la integridad de los datos de manufactura mientras se ejecutan los mantenimientos pendientes, registrando cada intento de acceso o modificación en una bitácora de auditoría.
- **Atiende:** Servicios de seguridad e intercambio de información.

IV. Respaldos de información

Para garantizar la disponibilidad e integridad de los activos de información de la empresa automotriz, la administración de respaldos se regirá bajo los siguientes pilares técnicos y estratégicos:

- **Implementación de la Estrategia 3-2-1:** Se establecerá un esquema donde existan **3 copias** de los datos (la original y dos respaldos), almacenadas en **2 medios** distintos (ej. Disco local de alta velocidad para recuperación rápida y Almacenamiento en la Nube), con **1 copia fuera de sitio** (*off-site*). Esta copia externa es crítica para el centro de diseño en Múnich, debiendo situarse en una región geográfica con bajo riesgo sísmico.
- **Clasificación Basada en el BIA (Business Impact Analysis):** No toda la información se respalda igual. Se priorizarán los diseños de hardware premium, bases de datos de manufactura (DB2, Oracle, SQL Server) y código fuente multimedia, asignándoles un **RPO (Objetivo de Punto de Recuperación)** cercano a cero para minimizar la pérdida de datos en caso de falla.
- **Cifrado e Integridad de los Datos:** Todos los respaldos deberán estar cifrados tanto en tránsito como en reposo utilizando algoritmos de grado industrial (AES-256). Se utilizarán funciones *hash* para verificar la integridad de las copias y asegurar que la información no haya sido alterada durante el proceso de almacenamiento.

- **Automatización y Ventanas de Ejecución:** Para evitar afectar la productividad de las plantas ensambladoras, los respaldos completos se programarán en horas de baja carga operativa, mientras que los respaldos incrementales o diferenciales se ejecutarán continuamente para capturar cambios en tiempo real sin degradar el rendimiento de la red Cisco.
- **Pruebas de Restauración y Cumplimiento de RTO:** Se realizará un calendario mensual de pruebas de restauración aleatorias. El objetivo es validar que el **RTO (Objetivo de Tiempo de Recuperación)** definido por la gerencia sea alcanzable, garantizando que los sistemas críticos puedan estar operativos en el menor tiempo posible tras un incidente.

V. Estrategias de seguridad

Para modernizar la infraestructura y proteger los activos críticos, se implementarán las siguientes estrategias:

- **Segmentación de Red mediante VLANs y Micro-segmentación:**
 - **Explicación:** Se dividirá la red lógica en diferentes segmentos aislados (VLANs) para separar el tráfico de las plantas ensambladoras, el área administrativa, el centro de diseño y la zona de servidores/mainframes.
 - **Justificación:** Evita el movimiento lateral de amenazas; si un equipo en la planta se infecta con *malware* (como por el uso de *Warzone*), la infección no podrá llegar a los mainframes o a las bases de datos críticas de manufactura.
- **Despliegue de Firewalls de Nueva Generación (NGFW):**
 - **Explicación:** Sustitución del equipo Cisco obsoleto por dispositivos que integren inspección profunda de paquetes (DPI), filtrado de contenido web y control de aplicaciones.
 - **Justificación:** Permite bloquear aplicaciones no autorizadas (Shadow IT) y detectar intentos de explotación en los motores Oracle y DB2 que actualmente carecen de parches de seguridad.

- **Implementación de Túneles VPN Site-to-Site con Cifrado Robusto:**
 - **Explicación:** Establecimiento de conexiones cifradas (IPsec) permanentes para la comunicación entre las tres plantas y el centro de diseño en Múnich.
 - **Justificación:** Garantiza que el intercambio de propiedad intelectual y diseños premium a través de internet sea confidencial e íntegro, mitigando el riesgo de interceptación de datos.
- **Sistemas de Detección y Prevención de Intrusiones (IDS/IPS):**
 - **Explicación:** Colocación de sensores en puntos estratégicos de la red para monitorear el tráfico en busca de patrones de ataque conocidos.
 - **Justificación:** Actúa como una capa de seguridad crítica para proteger los sistemas que tienen un ciclo de vida de mantenimiento lento, como los mainframes y servidores Unix.
- **Control de Admisión de Red (NAC):**
 - **Explicación:** Sistema que valida la identidad y el estado de seguridad de cualquier dispositivo antes de permitirle unirse a la red corporativa.
 - **Justificación:** Asegura que solo los equipos registrados en el inventario de hardware tengan acceso, bloqueando dispositivos externos o routers no autorizados instalados por los empleados.

VI. Políticas y controles de seguridad

Para asegurar que la transferencia de datos técnicos y administrativos sea protegida contra intercepciones o modificaciones no autorizadas, se establecen las siguientes medidas:

Políticas de Seguridad (Marco Administrativo)

- **Política de Clasificación de la Información:** Se establece la obligatoriedad de etiquetar todo activo de información (p. ej., "Público", "Uso Interno", "Confidencial" o "Restringido") antes de su envío. Esto define el nivel de protección que el dato requiere durante su intercambio.
- **Acuerdos de Confidencialidad (NDA):** Todo empleado o tercero con acceso a diseños de hardware y software debe firmar convenios legales que prohíban la divulgación de información propietaria.

Política de Uso Aceptable (AUP): Documento que dicta las reglas sobre qué plataformas y métodos son permitidos para el intercambio de archivos, prohibiendo explícitamente el uso de servicios de almacenamiento personal en la nube o herramientas de acceso remoto no oficiales como *AnyDesk*.

Controles de Seguridad (Implementación Técnica)

- **Cifrado de Datos en Tránsito (TLS/SSL y IPsec):** Toda comunicación entre las plantas y el centro de diseño debe realizarse a través de túneles VPN cifrados que utilicen protocolos robustos para garantizar la confidencialidad de los datos mientras viajan por redes públicas.
- **Firmas Digitales y No Repudio:** Se implementará el uso de certificados digitales para firmar documentos técnicos y aprobaciones de diseño. Esto garantiza la integridad del mensaje y asegura que el emisor no pueda negar haber enviado la información.
- **Sistemas de Prevención de Fuga de Datos (DLP):** Control técnico que monitorea y bloquea el intercambio de archivos que contengan patrones de propiedad intelectual protegida (como planos de motores o código fuente) a través de correo electrónico o dispositivos USB no autorizados.
- **Protocolos de Transferencia Segura (SFTP/HTTPS):** Se eliminará el uso de protocolos inseguros (como FTP simple) para el intercambio de archivos de gran tamaño, exigiendo canales que cifren tanto las credenciales de acceso como el contenido transferido.

VII. Monitoreo

Para garantizar la visibilidad total de la infraestructura y la detección oportuna de incidentes, se implementará un ecosistema de monitoreo centralizado basado en las siguientes capas técnicas:

- **Inteligencia de Seguridad y Correlación (SIEM - Splunk):**
 - Se utilizará **Splunk** para centralizar y correlacionar los logs de los 30 servidores Windows, los 15 servidores Unix/Mainframes y los 15,000 endpoints.
 - El enfoque principal será la detección de anomalías en el comportamiento de los usuarios (UBA) para identificar accesos no autorizados a diseños premium derivados del "Full Access" actual.
- **Orquestación y Respuesta Automatizada (SOAR):**
 - Se integrará una plataforma **SOAR** para automatizar el triaje de incidentes. Por ejemplo, ante la detección de software no autorizado como *Call of Duty* o *AnyDesk*, el SOAR ejecutará automáticamente un playbook para aislar el equipo de la red y generar el reporte de incidente en tiempo real.

- **Monitoreo de Salud y Rendimiento (Prometheus y Grafana):**
 - Se desplegará **Prometheus** para la recolección de métricas de hardware y servicios, visualizadas en tableros de **Grafana**.
 - Esto es crítico para monitorear el equipo Cisco con más de 5 años de antigüedad, permitiendo predecir fallas por desgaste de componentes antes de que afecten la producción en las plantas.
- **Monitoreo de Actividad de Bases de Datos (DAM):**
 - Dado que los motores Oracle, DB2 y SQL Server carecen de parches, se implementará un monitoreo específico sobre las consultas y modificaciones en estas tablas. Cualquier intento de inyección de código o extracción masiva de datos de manufactura disparará una alerta crítica inmediata.
- **Control de Acceso Físico y Bitácoras de Identidad:**
 - Se integrará el sistema de **gafetes con ID** a la plataforma de monitoreo para registrar cada entrada y salida de las plantas y laboratorios.
 - El sistema generará alertas si un empleado intenta acceder a áreas restringidas fuera de su horario laboral o si se detecta un "ingreso doble" con la misma credencial, resolviendo la falta de control físico reportada.

- **Monitoreo Ambiental en el Centro de Diseño (Múnich):**
- Se instalarán sensores de actividad sísmica y condiciones ambientales conectados al SIEM. Ante cualquier vibración que supere el umbral de seguridad, el sistema activará automáticamente los protocolos de emergencia y evacuación para proteger al personal.